

SESSION TECHNIQUE

20 MINUTES

NIVEAU DEBUTANT

Cybersécurité défensive

assistée par l'IA générative

Claude Code — GitHub Copilot CLI



Ludovic Toinel



« GPT-5.5 d'OpenAI
rivalise avec Claude
Mythos d'Anthropic
en matière de
capacités de
<https://intelligence-artificielle.developpez.com/>
cyberattaque »



« Project Glasswing
réunit 40
entreprises pour
colmater ces failles
avant que les
<https://www.science-et-vie.com>
hackers ne les
trouvent »

Claude Mythos

Le constat

Combien d'organisations déploient régulièrement du code vulnérable en production sans en avoir connaissance ?

68%

des breaches impliquent
un facteur humain non-malveillant

Source : Verizon DBIR 2024

194j

MTTI — délai moyen pour
détecter une compromission

Source : IBM Cost of a Data Breach 2024

4,4M\$

coût moyen global d'un data breach

Source : IBM Cost of a Data Breach 2025

+180%

explosion YoY de l'exploit
de vulns comme vecteur initial

Source : Verizon DBIR 2024

L'enjeu n'est pas l'erreur du développeur, mais l'absence de contrôle continu intégré au cycle de développement.

C'est qui qui a fuité aujourd'hui ?

(Pour savoir pourquoi ça fuité toujours, c'est par ici)

Pour signaler une nouvelle fuite : fuites @ imirhil.fr
(Clef GPG 0xAD12FD395433D31D disponible ici)

413

fuites signalées



Fuite standard



Données sensibles



Confirmée



Revendiquée (crédible)



Revendiquée (peu fiable)

3 mai 2026



Fédération Française de Basketball

- Nom, prénom
- Date de naissance
- Adresse postale
- Adresse électronique
- Numéro de téléphone
- Numéro de licence
- Club
- Source



3 mai 2026



Interrail

- Nom, prénom
- Adresse email
- Adresse postale
- Numéro de téléphone
- Numéro de passport, date de délivrance, date d'expiration
- Accompagnants
- Source



30 avril 2026



Umanens

- Nom, prénom
- Adresse postale
- Adresse email
- Numéro de téléphone
- Date et lieu de naissance
- Composition familiale

<https://bonjourlafuite.eu.org>

Have I Been Pwned

Check if your email address is in a data breach

ludo@gmail.com

Check

Using Have I Been Pwned is subject to the [terms of use](#)

Email Breach History

Timeline of data breaches affecting your email address

33

Data Breaches

Oh no — pwned! This email address has been found in multiple data breaches. Review the details below to see where your data was exposed.

Six piliers de la cybersécurité défensive

Audit de code et SAST

01

OWASP Top 10 · CVE des dépendances · secrets · cryptographie legacy

DevSecOps et chaînes CI/CD

02

Revue de PR · gate CI/CD · SBOM · pre-commit · Dependabot

Détection et SIEM

03

Analyse de journaux · YARA · Sigma · Splunk · ELK

Réponse à incident et forensique

04

Triage · memdump · reverse · chronologie · rapport DFIR

Threat Intelligence

05

CVE · IOC · MITRE ATT&CK · profilage APT · OSINT

Durcissement et conformité

06

IaC · Cloud · Kubernetes · CIS · RGPD · NIS2 · OPA

01

Audit de code et SAST

Analyser le code existant pour identifier vulnérabilités, secrets et CVE avant exploitation

DOMAINES D'APPLICATION

OWASP Top 10

Secrets

CVE

Cryptographie

SARIF

Claude Code

ANTHROPIC

\$ claude "Audit OWASP Top 10 sur src/ → rapport SARIF priorisé CVSS"

\$ claude "Détection des secrets hardcodés et propose migration Vault"

\$ claude "Liste les CVE des dépendances avec une analyse des exploitabilités possibles sur le projet"

\$ claude "Trouve usages MD5/SHA1 et propose bcrypt/argon2"

Différenciation

Analyse contextuelle multi-fichiers, génère le fix + le test associé

GitHub Copilot CLI

GITHUB

\$ copilot -p "Analyse le chemin des entrées utilisateur depuis l'API jusqu'à la base de données pour détecter des injections potentielles."

\$ copilot -p "Liste les CVE présentes dans mon fichier package.json en précisant leur score de criticité et leur exploitabilité réelle."

\$ copilot -p "Identifie une vulnérabilité XSS dans ce dossier, génère le fix et crée le test unitaire qui valide la correction."

\$ copilot -p "Réécris les fonctions d'authentification pour intégrer une validation de jeton JWT plus robuste."

Différenciation

Agent natif GitHub : accès direct PR/issues via MCP GitHub, choix Claude Sonnet 4.5 ou GPT-5

02

DevSecOps et chaînes CI/CD

Intégrer la sécurité dès la conception, à chaque étape du cycle de développement (revue de PR, CI/CD, registre, exécution)

DOMAINES D'APPLICATION

Revue de PR

Gate CI/CD

SBOM

Pre-commit

Signature

Claude Code

ANTHROPIC

\$ claude "Crée un workflow GitHub Actions Trivy+Semgrep, gate CVSS>7"

\$ claude "Génère pre-commit hook gitleaks + détection IaC"

\$ claude "Ajoute tests sécu OWASP A1-A3 pour cette PR"

\$ claude "Configure SBOM CycloneDX + signature Cosign"

Différenciation

Génère le YAML complet d'un pipeline agentique multi-étapes, avec contexte du repo

GitHub Copilot CLI

GITHUB

\$ copilot -p "Active Dependabot + CodeQL et configure le scanning"

\$ copilot -p "Crée workflow Actions Trivy+Semgrep, gate CVSS>7"

\$ copilot -p "Active push protection contre les secrets sur ce repo"

\$ copilot -p "Configure SBOM CycloneDX + signature Cosign en CI"

Différenciation

Intégration GitHub native : Actions, Dependabot, CodeQL, push protection — pilotés via MCP
GitHub

03

Détection et SIEM

Analyser les journaux, élaborer des règles de détection (YARA, Sigma, Snort) et conduire la recherche de menaces

DOMAINES D'APPLICATION

Journaux

YARA

Sigma

Splunk

ELK

Hunting

Claude Code

ANTHROPIC

```
$ claude "Analyse auth.log : identifie patterns bruteforce SSH"
```

```
$ claude "Génère une règle YARA pour ce sample malware"
```

```
$ claude "Convertis cette règle Snort en Sigma rule"
```

```
$ claude "Écris une requête Splunk SPL pour DNS tunneling"
```

Différenciation

Comprend les TTP d'attaque et génère des règles de détection de qualité prod

GitHub Copilot CLI

GITHUB

```
$ copilot -p "Analyse auth.log: bruteforce SSH"
--allow-tool='shell(grep)'
```

```
$ copilot -p "Extrait IPs malicieuses de eve.json"
--allow-tool='shell(jq)'
```

```
$ copilot -p "Génère règle YARA depuis IOC observés"
```

```
$ copilot -p "Écris requête Splunk SPL pour DNS tunneling"
```

Différenciation

Shell sandboxé via --allow-tool, MCP GitHub natif pour issues d'incident

04

Réponse à incident et forensique

Triage des alertes, analyse de mémoire, rétro-ingénierie et reconstitution de la chronologie d'incident

DOMAINES D'APPLICATION

Triage

Mémoire

Reverse

Chronologie

Rapport DFIR

Claude Code

ANTHROPIC

```
$ claude "Analyse ce memdump (volatility): processus suspects"
```

```
$ claude "Reverse ce PowerShell obfusqué et explique son intent"
```

```
$ claude "Construis timeline forensique depuis /var/log + evtx"
```

```
$ claude "Génère rapport d'incident format SANS DFIR"
```

Différenciation

Reverse, analyse comportementale et narration claire d'un incident complexe

GitHub Copilot CLI

GITHUB

```
$ copilot -p "Volatility pslist sur memdump.raw"  
--allow-tool='shell(vol)'
```

```
$ copilot -p "Extrait IOCs depuis capture.pcap"  
--allow-tool='shell(tshark)'
```

```
$ copilot -p "Décode payload base64 multi-couches en sandbox"
```

```
$ copilot -p "Construis timeline DFIR via plaso/log2timeline"
```

Différenciation

Pilote les outils DFIR sous garde-fou --allow-tool (volatility, tshark, plaso)

05

Threat Intelligence

Cartographier les TTP sur MITRE ATT&CK, enrichir les IOC, profiler les groupes APT et évaluer l'exploitabilité des CVE

DOMAINES D'APPLICATION

CVE

IOC

MITRE ATT&CK

APT

OSINT

Claude Code

ANTHROPIC

```
$ claude "Mappe ces TTP observées sur la matrice MITRE ATT&CK"
```

```
$ claude "Enrichis ces IOC (IP/hash/domain) avec contexte CTI"
```

```
$ claude "Analyse CVE-2024-XXXX et exploitabilité dans notre stack"
```

```
$ claude "Profile cet APT depuis les artefacts (TTP, infra, malware)"
```

Différenciation

Synthèse CTI structurée, mapping ATT&CK automatique et évaluation d'impact métier

GitHub Copilot CLI

GITHUB

```
$ copilot -p "Recherche Shodan exposed redis" --allow-tool='shell(curl)'
```

```
$ copilot -p "Fetch derniers CVE openssl via NVD API"
```

```
$ copilot -p "Batch enrich IPs sur AbuseIPDB et VirusTotal"
```

```
$ copilot -p "Crée issue GitHub avec rapport CTI consolidé"
```

Différenciation

MCP GitHub natif : crée directement issues / PR à partir des findings CTI

Cloudflare Security Events - AbuseIPDB Reporter

Advanced Python script to monitor Cloudflare firewall security events via GraphQL API with AbuseIPDB integration for threat intelligence and automated IP reporting. Features **cron integration** for continuous automated monitoring.

✓ Features

- **Smart Event Filtering:** Automatically filters out "hot" source events
- **IP Summary Dashboard:** Default table view with attack count per IP
- **AbuseIPDB Integration:**
 - IP reputation enrichment (country, ISP, abuse score)
 - Automated malicious IP reporting
 - Color-coded threat levels (● safe, ● suspicious, ● malicious)
- **Detailed Event View:** Debug mode with full event information
- **Audit Logging:** Automatic report.log for all AbuseIPDB submissions
- **Automated Cron Scheduling:** Pre-configured /etc/cron.d integration for hourly/daily monitoring
- **GraphQL Schema Introspection:** Built-in diagnostic tools

IP Address	Count	Country	ISP	Score	
4.235.98.10	32	Norway	Microsoft Corp	100%	●
15.235.151.203	20	Singapore	OVH	100%	●
129.212.239.206	8	Singapore	DigitalOcean	72%	●
12.74.98.86	1	USA	AT&T	0%	●

06

Durcissement et conformité

Durcir l'infrastructure (IaC, Cloud, Kubernetes) et démontrer la conformité (CIS, RGPD, NIS2, SOC 2)

DOMAINES D'APPLICATION

IaC

Cloud

Kubernetes

CIS

RGPD

NIS2

OPA

Claude Code

ANTHROPIC

```
$ claude "Audite Terraform AWS contre CIS Benchmark v3"
```

```
$ claude "Génère policy OPA Rego bloquant S3 publics"
```

```
$ claude "Cartographie le code vs RGPD article 32"
```

```
$ claude "Audit Kubernetes : RBAC, NetworkPolicies, PodSecurity"
```

Différenciation

Génère policy-as-code (OPA, Kyverno) et matrices de conformité actionnables

GitHub Copilot CLI

GITHUB

```
$ copilot -p "Durcis ssh_config selon CIS Level 1, montre le diff"
```

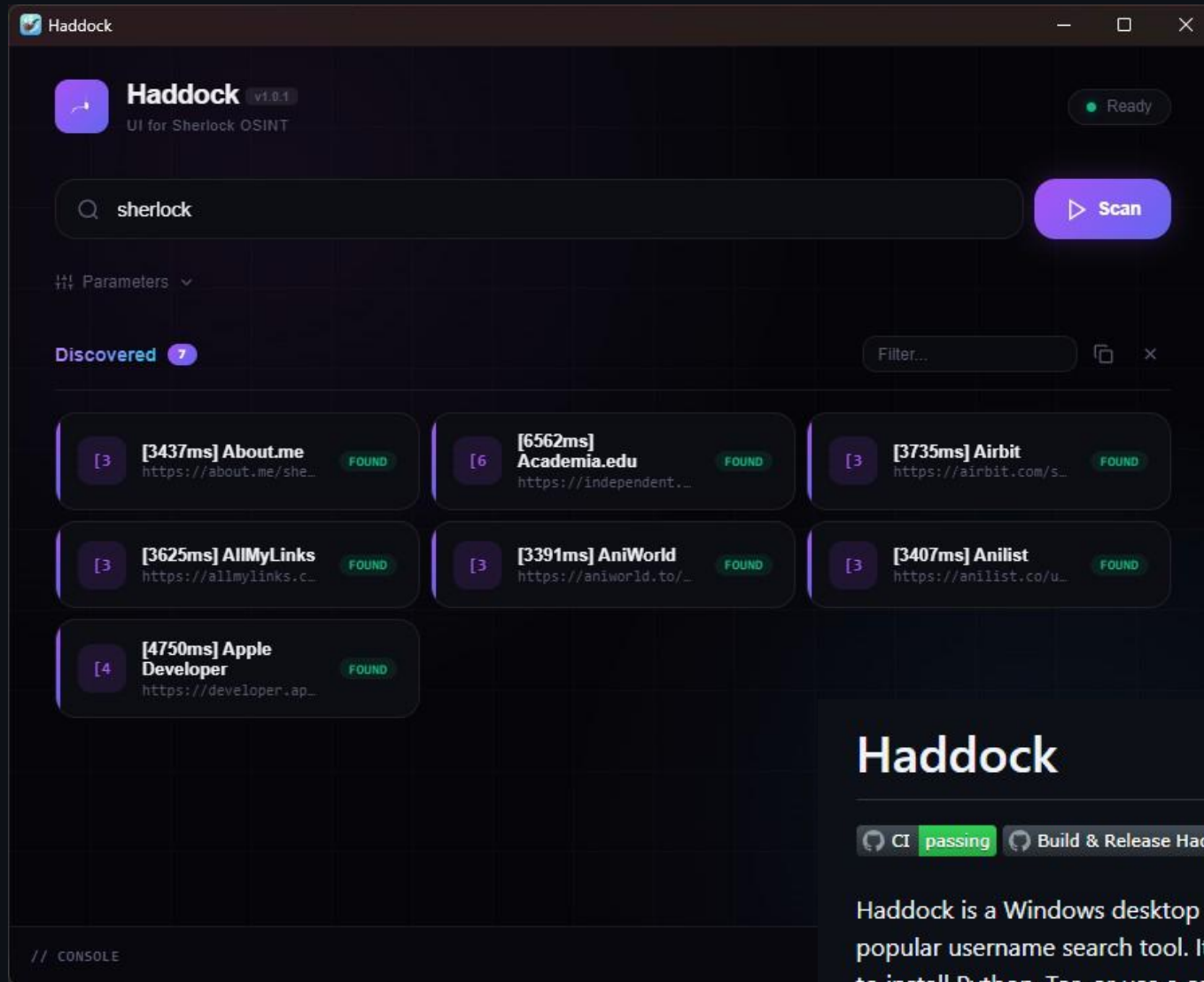
```
$ copilot -p "Scan Dockerfile" --allow-tool='shell(hadolint)'
```

```
$ copilot -p "Audit cluster K8s" --allow-tool='shell(kube-bench)'
```

```
$ copilot -p "Check Terraform avec checkov, propose les fixes"
```

Différenciation

Pilote scanners CIS/IaC sandboxés (kube-bench, checkov, hadolint, trivy)



Haddock

CI **passing** Build & Release Haddock **passing** License **MIT** Tauri **v2** Rust **stable** TypeScript **strict** Platform **Windows**

Haddock is a Windows desktop application that provides a clean, user-friendly interface for [Sherlock OSINT](#), the popular username search tool. It allows anyone to search for a username across 400+ social networks without needing to install Python, Tor, or use a command line.

Built with [Tauri](#) (Rust + TypeScript), Haddock embeds Python, Sherlock, and Tor directly in the installer — zero external dependencies.

Pour un usage plus avancé :

#	Skill	Stars	Focus	Source
1	Trail of Bits Code Audit Skills	5K	SAST with CodeQL, variant analysis	
2	Trail of Bits YARA Rule Authoring	5K	Malware detection engineering	
3	Snyk Fix	30	Automated vulnerability remediation with Snyk	
4	SecSkills Pentesting Plugin	40	Offensive security (16 skills + 6 AI agents)	
5	Claude Code OWASP	171	OWASP Top 10:2025, ASVS 5.0, Agentic AI security	
6	Trail of Bits Building Secure Contracts	5K	Smart contract security (11 skills)	
8	Awesome Claude Skills Security	225	SecLists integration, CTF, bug bounty agents	
9	Claude Agentic Framework Security	79	Threat modeling, security review, compliance (67 reusable skills)	

Précautions d'usage et limites

Risques à éviter

- Accorder une confiance aveugle au code généré
- Substituer ces outils à un audit ou pentest expert
- Négliger l'analyse des faux positifs
- Présumer que l'IA maîtrise le contexte métier
- Déployer un correctif sans revue humaine
- Transmettre des données sensibles sans anonymisation

Bonnes pratiques

- Positionner l'IA comme premier niveau de contrôle
- Combiner avec des outils établis (Semgrep, Trivy, Snyk)
- Former les équipes aux pratiques de prompting sécurité
- Maintenir une revue humaine sur les correctifs critiques
- Définir un seuil de blocage CI/CD (par exemple CVSS > 7)
- Tracer et auditer les prompts pour la conformité

La mise en production exige gouvernance, contrôles et formation continue au-delà de la simple démonstration technique.

**L'IA générative déplace la sécurité d'un contrôle final
vers un accompagnement continu intégré au cycle de développement.**

01

SAST

02

DevSecOps

03

Détection / SIEM

04

Forensique

05

Threat Intelligence

06

Durcissement

L'IA générative ne se substitue pas à l'expertise sécurité.

Elle apporte aux équipes de développement une vigilance sécurité continue.

Claude Code — Anthropic

GitHub Copilot CLI — GitHub